

Narrativa explicativa de la encuesta FAIR-STRIDE

1. Una historia de riesgos, números y amenazas con nombre y apellidos

En algún momento, todos hemos jugado al juego de la matriz de calor. Se toman unos cuantos riesgos, se les asignan colores (preferiblemente vivos) y se presenta el resultado a la Alta Dirección con aire grave. El problema, como bien sabe quien ha pasado por ahí, es que los colores no pagan las multas, no recuperan sistemas caídos ni convencen a un CFO escéptico.

La encuesta FAIR-STRIDE nace precisamente como antídoto contra el imperio de la intuición cromática. Su propósito es ayudar a las organizaciones a recorrer el camino que va de “creemos que este riesgo es alto” a “estimamos que la pérdida anual esperada puede situarse entre X e Y millones de euros, y estas son las amenazas que más contribuyen a ello”. Ese salto no es trivial, pero sí posible cuando se combinan dos ingredientes: un método para cuantificar (FAIR) y un método para pensar estructuradamente en las amenazas (STRIDE).

2. FAIR: cuando el riesgo se convierte en contabilidad

FAIR propone una herejía benigna: tratar el riesgo de ciberseguridad como una cuestión de frecuencia y magnitud. No se trata de adivinar el futuro, sino de aceptar que la incertidumbre puede modelarse con distribuciones, rangos y escenarios, y que la pregunta relevante no es “¿ocurrirá o no?” sino “¿con qué probabilidad y con qué impacto?”.

La encuesta explora hasta qué punto su organización ha abrazado esta herejía. ¿Utilizan modelos cuantitativos para priorizar inversiones? ¿Se apoyan en datos de incidentes propios o ajenos para estimar pérdidas? ¿Alguien, en algún punto, ha hecho una simulación de Monte Carlo que no fuera sólo para una presentación especialmente ambiciosa?

No se trata de buscar perfección matemática, sino de comprobar si la conversación sobre riesgo ha abandonado el terreno resbaladizo de las impresiones y se apoya, al menos en parte, en números defendibles. La encuesta es, en ese sentido, un espejo amable pero implacable.

3. STRIDE: poner orden en el zoológico de amenazas

El otro protagonista de esta historia es STRIDE, ese acrónimo que resume seis formas bastante humanas de hacer el mal (o de permitir, inadvertidamente, que ocurra): suplantación, manipulación, repudio, divulgación, denegación de servicio y abuso de privilegios.

Modelar amenazas con STRIDE consiste en mirar sistemas y procesos con la suspicacia profesional del paranoico razonable: ¿quién podría hacerse pasar por quién?, ¿qué datos podrían alterarse sin que nadie se diera cuenta?, ¿qué acciones se podrían negar después?, ¿qué sería de nosotros si este servicio crítico dejara de estar disponible justo el lunes a primera hora?.

La encuesta pregunta, en esencia, si esos ejercicios se hacen, con qué método, en qué fases del ciclo de vida y si sus resultados acaban influyendo en algo más que en los anexos de auditoría. El objetivo no es

coleccionar diagramas amenazantes, sino que cada amenaza relevante tenga una ficha en el inventario de riesgos que FAIR pueda cuantificar.

4. Cuando FAIR y STRIDE se encuentran (y hablan de dinero)

El verdadero encanto de FAIR-STRIDE no está en FAIR ni en STRIDE por separado, sino en la conversación que se produce cuando se sientan juntos. STRIDE ayuda a no olvidar amenazas importantes; FAIR ayuda a distinguir entre las que son muy graves pero improbables y las que son menos dramáticas pero mucho más frecuentes.

La encuesta explora este punto de encuentro: pregunta si las amenazas identificadas se traducen en escenarios cuantificados, si se mantienen catálogos reutilizables, si las decisiones sobre Zero Trust, segmentación o seguros cibernéticos se apoyan en algo más que en la intuición o la moda del momento. Se trata de saber si el matrimonio FAIR-STRIDE es un romance pasajero o un compromiso estable.

5. Propiedades de seguridad: más allá del triángulo clásico

Aunque el viejo triángulo de confidencialidad, integridad y disponibilidad sigue siendo útil, la práctica moderna exige prestar atención también a autenticidad, no repudio y autorización. La encuesta se adentra en cada una de estas propiedades, no con ánimo académico, sino con preguntas incómodas: ¿miden realmente cuántas identidades se suplantan?, ¿tienen idea del coste de un error de integridad discreto pero persistente?, ¿los mecanismos de no repudio son algo más que una cláusula en los contratos?, ¿saben cuánto les cuesta una hora de caída de su servicio más crítico?

Cada bloque de preguntas busca conectar propiedades abstractas con indicadores concretos y, cuando es posible, con euros. No porque el dinero sea la única medida importante, sino porque la asignación de recursos suele hablar ese idioma con más fluidez que el de las buenas intenciones.

6. Arquitectura, resiliencia y el inevitable Zero Trust

No podía faltar en este relato el personaje de moda: Zero Trust. Más allá del eslogan, la cuestión de fondo es sencilla: ¿se han revisado las arquitecturas pensando en que el perímetro ha dejado de ser una línea clara?, ¿se han modelado amenazas internas, laterales y de cadena de suministro?, ¿se han cuantificado los beneficios de segmentar, vigilar y limitar con más rigor quién puede hacer qué, desde dónde y en qué condiciones?.

La encuesta interroga también la resiliencia: no sólo si existen planes de continuidad, sino si los ciberincidentes ocupan un lugar central en ellos, si se han estimado los costes de interrupciones y si se han comparado esos costes con el precio de mejorar la redundancia, los backups o la gestión de crisis. Y, por supuesto, pregunta por el seguro cibernético: ¿es una decisión pensada o una casilla marcada para tranquilizar a terceros?

7. Datos, cultura y el factor humano (pero de verdad)

Detrás de cualquier modelo decente hay datos más o menos decentes. La encuesta intenta averiguar si la organización dispone de un repositorio de incidentes razonablemente fiable, si alguien se ha preocupado por la calidad de la información y si existe una figura responsable del gobierno de los datos de riesgo.

También mide la cultura, pero no en términos etéreos, sino en cuestiones concretas: ¿hay especialistas en cuantificación?, ¿la Alta Dirección entiende, al menos en lo esencial, qué es FAIR-STRIDE?, ¿las áreas de negocio participan en la evaluación de riesgos o delegan todo en los “de seguridad”? Es ahí donde muchas iniciativas prometedoras mueren: en el cruce entre la complejidad técnica y la atención limitada de quienes deciden.

8. Y ahora, ¿qué hacemos con todo esto?

Completada la encuesta, el lector se encontrará con un conjunto de puntuaciones, gráficos y quizá alguna sorpresa. La tentación de declararse “por encima de la media” será grande; es casi un reflejo de supervivencia. La propuesta de esta narrativa es otra: usar los resultados como punto de partida para conversaciones incómodas pero productivas.

Quizá descubran que cuantifican bastante bien los riesgos de confidencialidad, pero apenas han mirado la integridad. O que tienen una arquitectura que suena a Zero Trust pero sin un modelo de amenazas serio detrás. O que la cultura de datos es sólida, pero nadie ha dado el paso de conectar esos datos con decisiones de inversión.

FAIR-STRIDE no es una varita mágica, ni la encuesta un examen final. Son, en el mejor de los casos, un sistema de espejos que ayudan a ver la organización desde ángulos menos complacientes. A partir de ahí, la historia continúa, escrita entre incidentes evitados, proyectos mejor pensados y, con un poco de suerte, presupuestos de seguridad negociados con algo más que resignación.